

Seguridad para todos

Zequi Vázquez
@RabbitLair



¿Quién soy?

- Ezequiel "Zequi" Vázquez
- Desarrollo backend
- Sysadmin & DevOps
- Hacking & Seguridad
- Ponente en CONs desde 2013





¿Dónde trabajo?

swiftcircle

<http://swiftcircle.com>







Harley Davidson Iron 883





Contents

- 1 Historias corrientes
- 2 La vida de un proyecto
- 3 En resumen

Cómo detener el programa nuclear iraní

- Junio de 2010
- Empresa de seguridad bielorrusa VirusBlokAda
- Gusano que reprograma sistemas SCADA
- Cuatro vulnerabilidades críticas de Windows XP



¿Recordais la película "La Entrevista"?

- 24 de noviembre de 2014
- Guardians of Peace
- Se extrajeron más de 100 TB de información confidencial
- Gusano que explotaba vulnerabilidad en SMB



Esto no sale en las noticias

- 3 de febrero de 2016
- Grupo hacktivista “La 9 de Anon”
- Se filtran las cuentas completas de 2011 a 2016
- ¿El fallo? Una inyección SQL
- Explicación completa <http://goo.gl/2iVd3F>





Base de datos de Comisión de Elecciones

- 27 de marzo de 2016
- Anonymous & LulzSec
- Datos de 55 millones de votantes (¡huellas dactilares!)
- No se conocen las vulnerabilidades explotadas





Paraísos fiscales en el punto de mira

- 3 de abril de 2016
- Atacante anónimo, colabora con periodistas de investigación
- Información confidencial de más de 40 años (2.6 TB)
- Drupal 7 y Wordpress vulnerable (Revolution slider)



Datos personales de votantes ¿Eso se come?

- 4 de abril de 2016
- Atacante desconocido (¿norteamericano?)
- Datos personales de 49,611,709 votantes (6.9 GB)
- Mala encriptación, contraseña hardcodeada en código



¿Por qué conformarse con una web?

- 19 de abril de 2016
- SurfWatch descubre plan para infectar múltiples webs
- Thanatos/Alphabot, troyano para zombificar pcs (botnet)
- Ataque a infraestructura - NHL, Warner, Bethesda, LiveNation



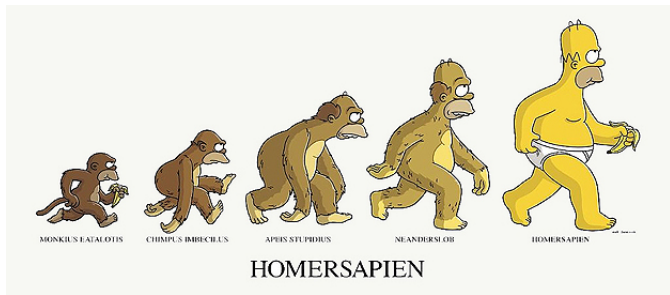


Pero no está todo perdido



¿Qué es un proyecto?

- Es mucho más que análisis, programación y producción
- Desde la primera idea del cliente hasta que se apaga el servidor
- Se trata de crear (y evolucionar) un producto
- Seguridad debe estar presente en todas las fases



Negociación y oferta

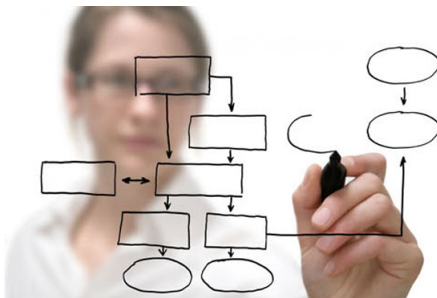
Desde el minuto cero

- La seguridad debe estar reflejada en los requisitos
- ¿Se necesita cumplir normativas específicas?
- Compromiso entre presupuesto y securización



Dibujando los planos

- El mejor defensor es alguien que sabe atacar
- Previsión del alcance de los fallos de seguridad
- La paranoia es una virtud
- Mínimo privilegio, granularidad de permisos ...



Durante el desarrollo

Asumamos la realidad

- El producto que vendemos es el software
- Los “malos” no crean los errores, sólo los aprovechan
- Responsables últimos de las vulnerabilidades del código



Durante el desarrollo

¿Qué es lo que ocurre?

- Desconocimiento de mejores prácticas en desarrollo seguro
- Elección de herramientas no adecuadas, o no mantenidas
- Programadores somos humanos, los humanos somos vagos



¿Y qué hacemos?

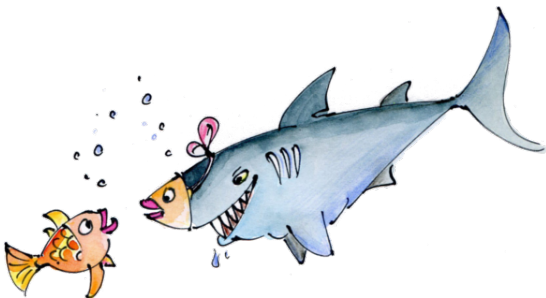
- Programación defensiva, mejorar el control de errores
- Adquirir un nivel básico de formación en seguridad
- Intentar pensar como lo haría un atacante



Durante el desarrollo

No sólo hay que cuidar el código

- Acceso a entornos de preproducción
- ¿Está el código realmente protegido de ojos indiscretos?
- Ojo con las preguntas en Stack Overflow y similares
- La seguridad en la oficina y los equipos



Durante el desarrollo

El responsable de seguridad

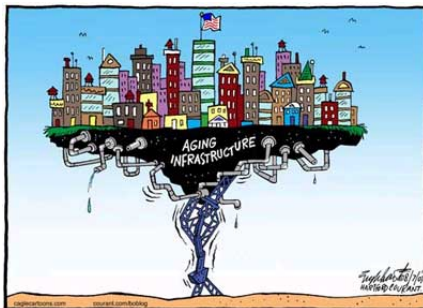
- Según el tamaño del equipo: departamento o persona
- Al menos, una persona debe velar por este aspecto



La infraestructura

Construir la casa por el tejado

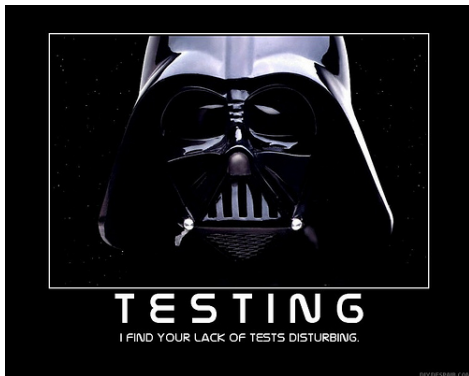
- El proyecto no sólo es código, abarca varias capas
- Tolerancia a fallos y alta disponibilidad
- Evitar denegación de servicio
- Versionado de configuración



Las pruebas

Antes de pasar a producción

- Auditoría de seguridad completa a código e infraestructura
- Idealmente, pruebas de seguridad a la par que funcionales
- Buena comunicación entre los miembros del equipo



La información es poder

- ¡Monitorizar todas las cosas!
- Inventario de máquinas, servicios, componentes ...
- Listas de distribución, actualizaciones y noticias



Recordemos el eslabón más débil

- Concienciar al cliente sobre la formación de usuarios
- El factor humano suele ser siempre el punto débil
- Una buena herramienta en malas manos: idea horrible





Shit happens

- Plan de recuperación en caso de emergencia
- Configurar, revisar y comprobar las copias de seguridad
- Auditoría forense: Saber qué ha pasado

**EMERGENCY USE
ONLY**

Otros puntos importantes

Aún hay tinta en el tintero

- Mantenimiento: Malabares, parches y otras drogas
- Ampliaciones del proyecto y nueva funcionalidad
- La deuda técnica: el teorema McFly
- El cierre de proyecto: informe post-mortem





- Inversión, no gasto
- Implicar a todos los actores
- Seguridad es un proceso
- ¡Formación!

Seguridad ante todo, pero ...



... jojo con la interfaz silla-teclado!



Aquí no se escapa nadie :)

Order dcamp-2016-226

Invoice date:
Saturday, April 23, 2016 - 00:31

Title	Precio unitario	Quantity	Total
DrupalCamp 2016 ticket (drupalcamp-ticket-2016)	0,00 €	2	0,00 €
Subtotal			82,64 €
IVA			0,00 €
Descuento patrocinador/ponente			-82,64 €
Order total			0,00 €

Esto es todo, amigos...



¡Gracias!

 @RabbitLair

 ezequielvazq[at]gmail[dot]com